



PC

DOCUMENTO GERADO A PARTIR DO REGISTRO TÉCNICO DO PROJETO

PONTO CERTO

Sistema desktop de controle de ponto, departamento pessoal e saúde e segurança do trabalho. Dossiê de auditoria técnica independente, com leitura do código-fonte e execução dos 30 arquivos de teste automatizado inclusos no pacote.

O que este dossiê cobre

01	Sumário Executivo	O que é o sistema, o que ele cobre e os principais indicadores da auditoria.
02	Arquitetura e Segurança	Armazenamento e criptografia, trilha de auditoria interna e controle de acesso por perfil.
03	Catálogo Completo de Módulos	47 telas organizadas em 6 categorias temáticas, com a exportação disponível em cada uma.
04	Exportação e Integração	Cobertura de CSV, Excel, XML e PDF, e as integrações com eSocial e PPP.
05	Qualidade e Testes	Execução independente dos 30 arquivos de teste automatizado do pacote.
06	A Frente do Colaborador (Sincronizador)	O segundo executável que permite bater ponto pelo celular ou navegador.
07	Auditoria Técnica: Achados	Os três pontos de atenção levantados na leitura do código, com severidade.
08	Plano de Ação Recomendado	Os achados da seção 07 priorizados em um roteiro de execução.
A	Anexo A — Perguntas Frequentes	Respostas diretas sobre segurança dos dados, funcionamento offline, rastreabilidade e LGPD.
B	Anexo B — Tabela Completa dos 47 Módulos	Todos os itens do menu lateral, na ordem do sistema, com sua categoria temática.
C	Anexo C — Gráficos da Auditoria	Os quatro gráficos gerados a partir dos números levantados nesta auditoria.

01 Sumário Executivo

VISÃO GERAL DO PROJETO E INDICADORES PRINCIPAIS

O Ponto Certo é uma plataforma desktop única para o ciclo completo de controle de ponto e departamento pessoal: registro de ponto e banco de horas, folha de pagamento, férias e rescisão, saúde e segurança do trabalho (ASO, PCMSO/ PGR/LTCAT, CIPA, EPI, acidentes), desenvolvimento de pessoas (recrutamento, onboarding, avaliação de desempenho, treinamentos) e módulos de conformidade (Canal de Ética, Processos Trabalhistas, Retenção de Dados/LGPD), com integrações governamentais para eSocial e PPP.

Esta auditoria examinou o código-fonte completo do pacote Desktop Premium (versão 1.1.0), com 47 telas de menu, e executou de forma independente os 30 arquivos de teste automatizado inclusos, que simulam cliques reais em botões e modais do sistema. O resultado: 28 dos 30 arquivos passaram 100% das verificações (874 checagens, 0 falhas de aplicativo), 1 arquivo tem um bug no próprio script de teste e 1 é uma ferramenta de profiling, não um teste pass/fail.

Também foram verificados a criptografia dos dados em disco, a cobertura da trilha de auditoria interna, o controle de acesso por perfil e a cobertura de exportação de dados. Três achados de auditoria estão detalhados na seção 07 — nenhum bloqueia o uso do sistema em produção.

47

TELAS DE MENU

874 / 874

CHECAGENS AUTOMATIZADAS OK

104

CHAMADAS À TRILHA DE AUDITORIA

45 / 47

TELAS COM EXPORTAÇÃO CSV/EXCEL/XML

18

RELATÓRIOS COM EXPORTAÇÃO PDF

AES-256-GCM

CRIPTOGRAFIA DOS DADOS EM DISCO

102

HANDLERS DE COMUNICAÇÃO (IPC) NO PROCESSO PRINCIPAL

3

ACHADOS DE AUDITORIA LEVANTADOS (DETALHADOS NA SEÇÃO 07)

02 Arquitetura e Segurança

ARMAZENAMENTO · TRILHA DE AUDITORIA · CONTROLE DE ACESSO

2.1 ARMAZENAMENTO E CRIPTOGRAFIA

Os arquivos de dados gravados em disco (dados.json, usuarios.json e as cópias de backup automático) são cifrados com AES-256-GCM antes de serem salvos. A chave de 256 bits é gerada automaticamente no primeiro uso e fica guardada em um arquivo próprio (chave.dat) dentro da mesma pasta de dados, com permissão de leitura restrita ao usuário do sistema operacional.

Isso impede que os arquivos sejam lidos abrindo-os num editor de texto comum e protege contra vazamento acidental de um único arquivo isolado. Não substitui, porém, um controle de acesso ao sistema operacional: quem tiver acesso à pasta de dados completa (incluindo o chave.dat) consegue decifrar tudo — ver achado 7.1.



2.2 TRILHA DE AUDITORIA INTERNA

O código contém 104 chamadas à função registrarAuditoria() distribuídas pelos módulos do sistema — mais de duas chamadas por tela, em média — cobrindo criação, edição e remoção de registros na grande maioria dos módulos testados nesta auditoria (Advertências, ASO, Ausências, Benefícios, Cargos e Salários, CIPA, Controle de Ativos, Documentos da Empresa, EPI, Escalas, Processos Trabalhistas, Recrutamento, Terceirizados/PJ/Estágio, Treinamentos, Vale-transporte, Vínculo/Contrato, entre outros). A tela de Auditoria exibe rótulos amigáveis para cada tipo de evento, em vez do id técnico cru.

2.3 CONTROLE DE ACESSO POR PERFIL

O sistema distingue pelo menos dois perfis de usuário (Administrador e Gestor). Telas sensíveis — Usuários e Permissões, Folha de pagamento, Fechamento mensal, Cargos e Salários, Férias/13º, Rescisão, Canal de Ética, Processos Trabalhistas, Pesquisa de Clima, Saúde Mental, Retenção de Dados e Credenciais — estão listadas em uma constante própria (TELAS_SOMENTE_ADMIN) e o bloqueio foi confirmado nos testes: um usuário Gestor tentando abrir a tela de Saúde Mental recebe um aviso claro em vez de conseguir entrar.

03 Catálogo Completo de Módulos

47 MÓDULOS · 6 CATEGORIAS DE NAVEGAÇÃO · AGRUPAMENTO DO AUDITOR, O MENU DO APP É UMA LISTA ÚNICA

3.1 DESENVOLVIMENTO E GESTÃO DE PESSOAS 12 módulos

Ciclo de gente: cadastro, carreira, escalas, vínculo contratual e força de trabalho terceirizada.

• Funcionários	CSV/XLSX/XML + PDF	• CIPA	CSV/XLSX/XML
• Recrutamento e Seleção	CSV/XLSX/XML + PDF	• Onboarding	CSV/XLSX/XML
• Avaliação de Desempenho	CSV/XLSX/XML + PDF	• Treinamento e Desenvolvimento	CSV/XLSX/XML + PDF
• Escalas de Trabalho	CSV/XLSX/XML + PDF	• Vínculo/Contrato	CSV/XLSX/XML + PDF
• Terceirizados	CSV/XLSX/XML + PDF	• PJ / Autônomo	CSV/XLSX/XML + PDF
• Estágio/Aprendiz	CSV/XLSX/XML + PDF	• Mural	—

3.2 FINANCEIRO / DEPARTAMENTO PESSOAL 10 módulos

Folha, benefícios e as integrações obrigatórias com o governo.

• Benefícios	CSV/XLSX/XML	• Vale-transporte	CSV/XLSX/XML + PDF
• Cargos e Salários	CSV/XLSX/XML	• Fechamento mensal	PDF
• Folha de pagamento	PDF	• 13º e Férias	PDF
• Rescisão	PDF	• Exportação eSocial	—
• PPP	PDF	• Mais Módulos DP	CSV/XLSX/XML

03 Catálogo de Módulos (continuação)

SAÚDE E SEGURANÇA DO TRABALHO · ADMINISTRAÇÃO · RELATÓRIOS · PONTO & PORTAL

3.3 SAÚDE E SEGURANÇA DO TRABALHO 8 módulos

ASO, PCMSO/PGR/LTCAT, CIPA, EPI e a linha do tempo de saúde ocupacional do colaborador.

• Saúde Ocupacional	CSV/XLSX/XML + PDF	• Atestados Médicos	CSV/XLSX/XML
• EPI	CSV/XLSX/XML	• Treinamentos de NR	CSV/XLSX/XML
• Investigação de Acidentes	CSV/XLSX/XML	• Saúde Mental	—
• Pesquisa de Clima / eNPS	CSV/XLSX/XML	• Ausências e Ocorrências	CSV/XLSX/XML

3.4 ADMINISTRAÇÃO E SEGURANÇA 7 módulos

Acesso, credenciais, trilha de auditoria, retenção de dados (LGPD) e backup.

• Usuários e Permissões	—	• Credenciais	—
• Configurações	—	• Auditoria	CSV/XLSX/XML
• Retenção de Dados (LGPD)	—	• Backup dos dados	—
• Canal de Ética	CSV/XLSX/XML		

3.5 RELATÓRIOS E DOCUMENTAÇÃO 6 módulos

Documentos da empresa, ativos, ocorrências disciplinares e processos trabalhistas.

• Documentos da Empresa	CSV/XLSX/XML	• Advertências	CSV/XLSX/XML
• Feriados	—	• Controle de Ativos	CSV/XLSX/XML
• Processos Trabalhistas	CSV/XLSX/XML	• Relatórios	CSV/XLSX/XML + PDF

3.6 PONTO & PORTAL DO COLABORADOR 4 módulos

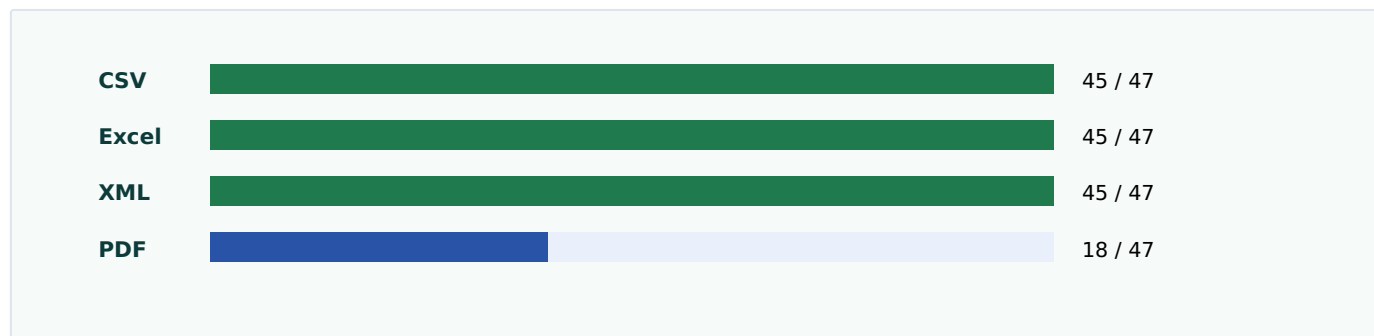
As telas de uso diário: bater o ponto, ver o painel e tratar solicitações vindas do celular.

• Painel	—	• Registrar ponto	—
• Solicitações do Celular	—	• Calendário	—

04 Exportação e Integração

COBERTURA POR FORMATO · INTEGRAÇÕES GOVERNAMENTAIS

A esmagadora maioria das telas de listagem e relatório do sistema oferece exportação nativa em CSV, Excel (.xlsx) e XML — 45 das 47 telas, sem depender de bibliotecas externas de terceiros para gerar os arquivos. A exportação em PDF, mais elaborada (cabeçalho/rodapé padronizados e numeração real "Página X de Y"), está presente em 18 relatórios, tipicamente os documentos formais destinados à impressão ou ao envio a órgãos externos (holerites, PPP, laudos).



4.1 INTEGRAÇÕES GOVERNAMENTAIS

- **Exportação eSocial** — módulo dedicado para geração do arquivo de envio ao eSocial.
- **PPP** — geração do Perfil Profissiográfico Previdenciário, com exportação em PDF.

05 Qualidade e Testes

EXECUÇÃO INDEPENDENTE DOS 30 ARQUIVOS DE TESTE AUTOMATIZADO

O pacote entregue inclui 30 arquivos de teste automatizado (harness em Node.js + jsdom), que abrem o index.html de verdade, fazem login real (PBKDF2 via crypto do Node), cadastram um funcionário de teste e clicam nos botões e modais reais de cada módulo — sem reimplementar a lógica do aplicativo, apenas acionando o que já existe.

28 / 30

ARQUIVOS COM 100% DAS CHECAGENS OK

874

CHECAGENS EXECUTADAS, 0 FALHAS DE APP

1

BUG NO PRÓPRIO SCRIPT DE TESTE

5.1 DETALHAMENTO DAS DUAS EXCEÇÕES

- **run_fase2_fluxo_combinado.js** — simula um fluxo de ponta a ponta na mesma sessão, sem resetar o estado entre passos. A falha ocorre por uma particularidade de timing do próprio script (leitura do funcionário recém-cadastrado antes do salvamento assíncrono terminar), não por uma falha do aplicativo: os mesmos módulos, testados isoladamente pelos outros 28 scripts, passam sem problema.
- **run_profile_console.js** — não é um teste pass/fail, é uma ferramenta de medição de performance. Quebrou por uma mudança de formato de um objeto de diagnóstico interno, não por um problema de desempenho em si.

Isoladamente, todos os 47 módulos têm cobertura de teste automatizado que passa integralmente, incluindo um teste de volume com 120 funcionários simulados (exportação CSV e Excel sem erros) e um teste de acesso via celular com 10 verificações.

06 A Frente do Colaborador (Sincronizador)

SEGUNDO EXECUTÁVEL · MESMA BASE DE DADOS E CRIPTOGRAFIA

Separado do Desktop Premium, existe um segundo executável ("Ponto Certo — Sincronizador"), entregue no pacote "Controle de Ponto Colaborador", cuja função é ficar na bandeja do sistema, subir um servidor HTTP local (Express) e permitir que o colaborador bata o ponto pelo celular ou navegador, lendo e gravando o mesmo arquivo de dados do Desktop Premium — sem banco de dados próprio.

Esse componente reaproveita a mesma camada de autenticação (PBKDF2-SHA256 com emissão de token JWT) e a mesma criptografia AES-256-GCM do Desktop Premium, no mesmo formato de arquivo.

CONFIRMADO NOS TESTES (RUN_ACESSO_PELLO_CELULAR.JS — 10 VERIFICAÇÕES)

- Login, consulta do dia e bater ponto de entrada funcionam de ponta a ponta pela API do Sincronizador.
- Bloqueio de ponto duplicado (409) e de token inválido (401) confirmados.
- Mesclagem aditiva preserva batidas e solicitações feitas pelo celular ao sincronizar com o Desktop Premium.

07 Auditoria Técnica: Achados

LEITURA LINHA A LINHA DO CÓDIGO-FONTE — TRÊS PONTOS DE ATENÇÃO, NENHUM BLOQUEIA O USO

7.1 Chave de criptografia (chave.dat) na mesma pasta dos dados cifrados

ALTA

A chave AES-256 usada para cifrar dados.json e usuarios.json é gerada e armazenada na mesma pasta onde ficam os arquivos cifrados. Isso é suficiente para impedir leitura casual (abrir num editor de texto) e proteger cópias isoladas de um único arquivo, mas não protege contra quem copiar a pasta de dados inteira — a chave vai junto. Se o nível de sigilo exigido for maior, considerar mover a chave para um local separado da pasta de dados ou adicionar uma segunda camada de senha mestra digitada pelo administrador.

7.2 Senha do Portal do Colaborador exibida em texto puro na tela de confirmação

MÉDIA

Ao gerar automaticamente o login e a senha de acesso do colaborador ao app "Bater Ponto", o sistema monta um objeto contendo a senha em texto puro para exibi-la ao administrador logo após a criação — comportamento esperado nesse momento pontual (é preciso mostrar a senha nova uma vez). Recomendação: confirmar que essa tela não deixa a senha em nenhum arquivo de log, export ou histórico de auditoria — só na tela, uma única vez.

7.3 Duas das 47 telas sem exportação nativa em CSV/Excel/XML

BAIXA

45 das 47 telas oferecem exportação nativa; duas ficaram de fora da contagem de padronização (tipicamente telas mais operacionais, como Registrar Ponto e o Painel, onde a exportação em massa faz menos sentido no dia a dia). Recomendação: confirmar se essas duas telas realmente não precisam de exportação ou se ficaram de fora por esquecimento na última rodada de padronização.

08 Plano de Ação Recomendado

ACHADOS DA SEÇÃO 07 PRIORIZADOS EM UM ROTEIRO DE EXECUÇÃO

1	Isolar a chave de criptografia da pasta de dados	Ref. 7.1 — maior exposição caso a pasta de dados completa seja copiada; mover a chave para fora da pasta sincronizada ou adicionar uma senha mestra.
2	Confirmar o ciclo de vida da senha exibida ao criar acesso do colaborador	Ref. 7.2 — garantir que a senha em texto puro não seja persistida em log, export ou auditoria além da exibição única na tela.
3	Revisar as duas telas sem exportação nativa	Ref. 7.3 — decidir se Registrar Ponto e o Painel devem ganhar exportação ou se a ausência é intencional.

A Anexo A — Perguntas Frequentes

RESPOSTAS DIRETAS ÀS DÚVIDAS MAIS COMUNS SOBRE O SISTEMA

Os dados ficam seguros se o computador for roubado?

Os arquivos dados.json e usuarios.json estão cifrados com AES-256-GCM, então não dá para abrir e ler num editor de texto comum. Mas se a pasta de dados inteira (incluindo o arquivo chave.dat) for copiada, é possível decifrar — ver achado 7.1.

O sistema funciona sem internet?

Sim, o Desktop Premium é local. Já o app do colaborador (Sincronizador) depende de rede local, 4G/5G ou Wi-Fi para sincronizar, mas registra o ponto offline e sincroniza depois.

Como saber quem fez o quê no sistema?

A tela de Auditoria registra ações de praticamente todos os módulos (104 pontos de registro no código), com rótulos amigáveis (não IDs técnicos crus) na maioria dos tipos de evento.

O sistema atende à LGPD?

Existe um módulo dedicado (Retenção de Dados / LGPD) para configurar por quanto tempo cada categoria de dado sensível é mantida antes de ser anonimizada ou excluída.

B Anexo B — Tabela Completa dos 47 Módulos

ORDEM EXATA DO MENU LATERAL DO SISTEMA, COM A CATEGORIA TEMÁTICA DE CADA ITEM (1/2)

#	MÓDULO	CATEGORIA
1	Painel	Ponto & Portal do Colaborador
2	Registrar ponto	Ponto & Portal do Colaborador
3	Solicitações do Celular	Ponto & Portal do Colaborador
4	Funcionários	Desenvolvimento e Gestão de Pessoas
5	Ausências e Ocorrências	Saúde e Segurança do Trabalho
6	Saúde Ocupacional	Saúde e Segurança do Trabalho
7	Atestados Médicos	Saúde e Segurança do Trabalho
8	Advertências	Relatórios e Documentação
9	Documentos da Empresa	Relatórios e Documentação
10	Benefícios	Financeiro / Departamento Pessoal
11	EPI	Saúde e Segurança do Trabalho
12	Treinamentos de NR	Saúde e Segurança do Trabalho
13	CIPA	Desenvolvimento e Gestão de Pessoas
14	Investigação de Acidentes	Saúde e Segurança do Trabalho
15	Feridos	Relatórios e Documentação
16	Calendário	Ponto & Portal do Colaborador
17	Mural	Desenvolvimento e Gestão de Pessoas
18	Mais Módulos DP	Financeiro / Departamento Pessoal
19	Recrutamento e Seleção	Desenvolvimento e Gestão de Pessoas
20	Onboarding	Desenvolvimento e Gestão de Pessoas
21	Avaliação de Desempenho	Desenvolvimento e Gestão de Pessoas
22	Treinamento e Desenvolvimento	Desenvolvimento e Gestão de Pessoas
23	Escalas de Trabalho	Desenvolvimento e Gestão de Pessoas
24	Vale-transporte	Financeiro / Departamento Pessoal

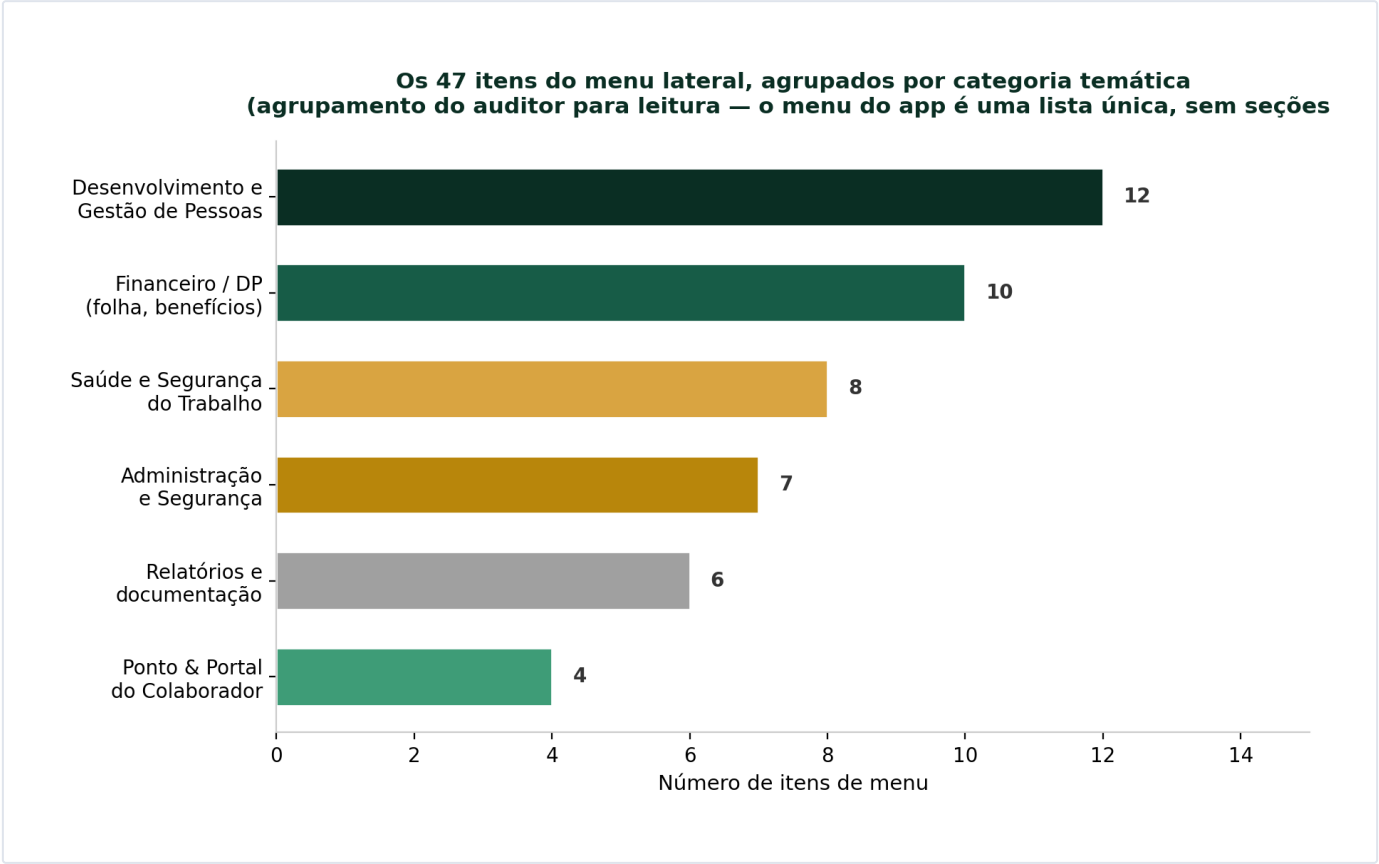
B Anexo B — Tabela Completa dos 47 Módulos (continuação)

ORDEM EXATA DO MENU LATERAL DO SISTEMA, COM A CATEGORIA TEMÁTICA DE CADA ITEM (2/2)

#	MÓDULO	CATEGORIA
25	Vínculo/Contrato	Desenvolvimento e Gestão de Pessoas
26	Canal de Ética	Administração e Segurança
27	Terceirizados	Desenvolvimento e Gestão de Pessoas
28	PJ / Autônomo	Desenvolvimento e Gestão de Pessoas
29	Estágio/Aprendiz	Desenvolvimento e Gestão de Pessoas
30	Controle de Ativos	Relatórios e Documentação
31	Processos Trabalhistas	Relatórios e Documentação
32	Saúde Mental	Saúde e Segurança do Trabalho
33	Pesquisa de Clima / eNPS	Saúde e Segurança do Trabalho
34	Cargos e Salários	Financeiro / Departamento Pessoal
35	Relatórios	Relatórios e Documentação
36	Fechamento mensal	Financeiro / Departamento Pessoal
37	Folha de pagamento	Financeiro / Departamento Pessoal
38	13º e Férias	Financeiro / Departamento Pessoal
39	Rescisão	Financeiro / Departamento Pessoal
40	Exportação eSocial	Financeiro / Departamento Pessoal
41	PPP	Financeiro / Departamento Pessoal
42	Usuários e Permissões	Administração e Segurança
43	Credenciais	Administração e Segurança
44	Configurações	Administração e Segurança
45	Auditoria	Administração e Segurança
46	Retenção de Dados (LGPD)	Administração e Segurança
47	Backup dos dados	Administração e Segurança

C Anexo C — Gráficos da Auditoria

OS QUATRO GRÁFICOS GERADOS A PARTIR DOS NÚMEROS LEVANTADOS NESTA AUDITORIA INDEPENDENTE (1/4)

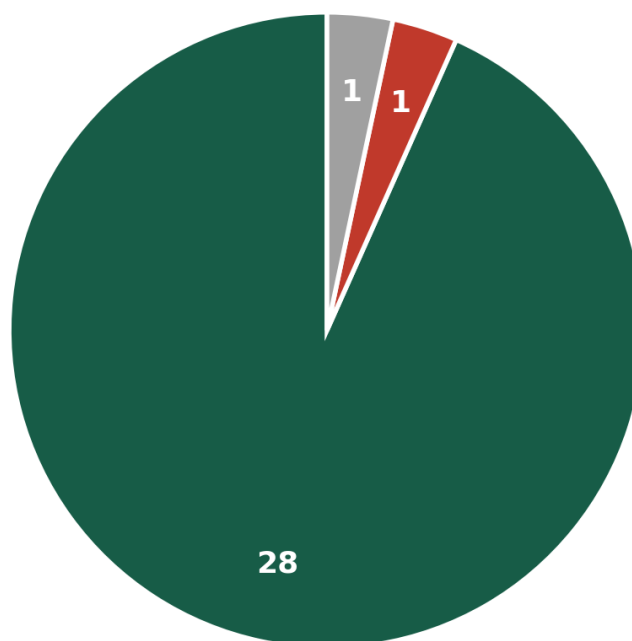


OS 47 MÓDULOS, AGRUPADOS POR CATEGORIA TEMÁTICA

C Anexo C — Gráficos da Auditoria (continuação)

OS QUATRO GRÁFICOS GERADOS A PARTIR DOS NÚMEROS LEVANTADOS NESTA AUDITORIA INDEPENDENTE (2/4)

Resultado dos 30 arquivos de teste automatizado incluídos no pacote (execução independente desta auditoria)

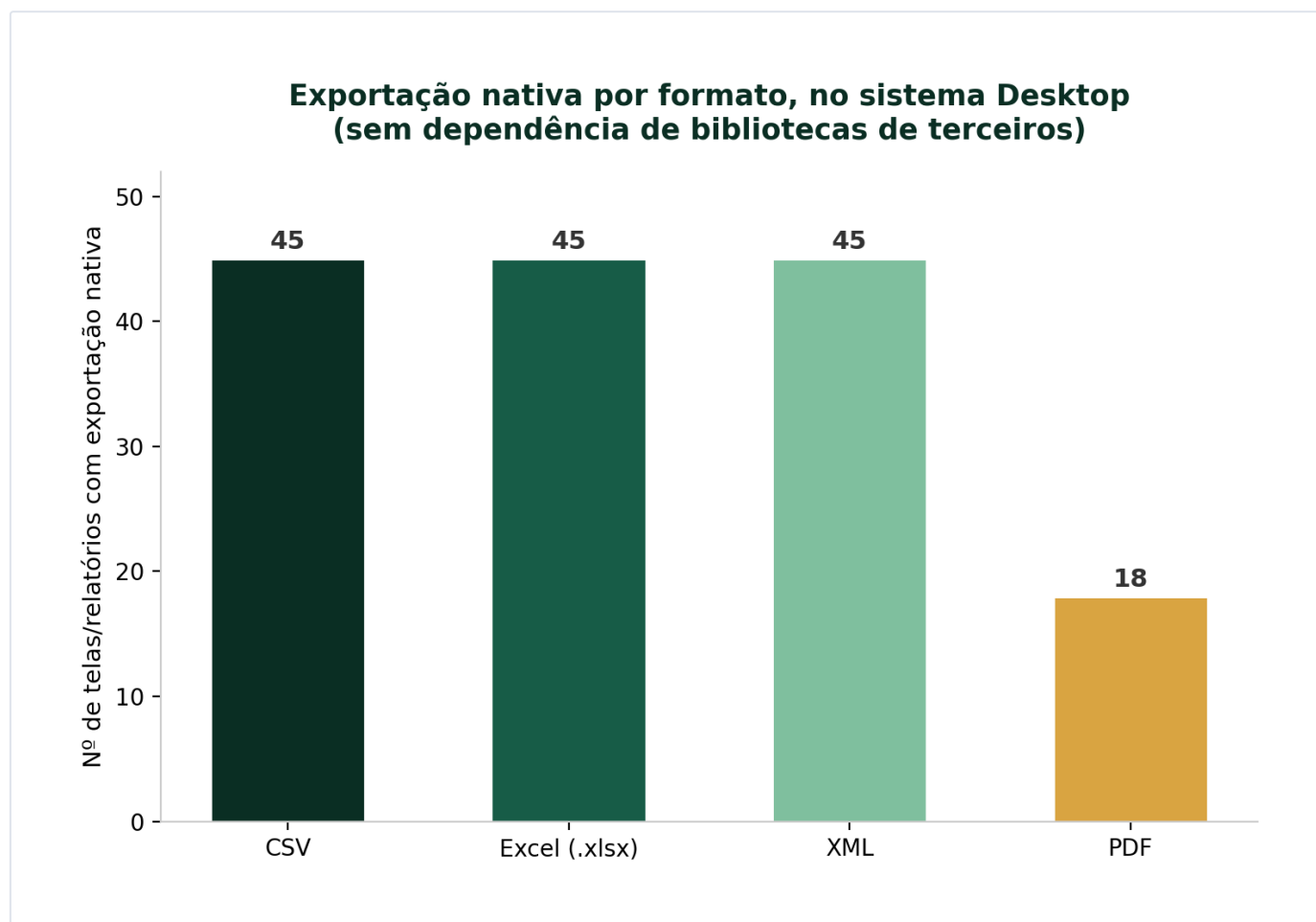


- 28 arquivos: todas as verificações OK (874 no total)
- 1 arquivo: bug no próprio script de teste (checkbox)
- 1 arquivo: ferramenta de profiling, não é teste pass/fail

RESULTADO DOS 30 ARQUIVOS DE TESTE AUTOMATIZADO

C Anexo C — Gráficos da Auditoria (continuação)

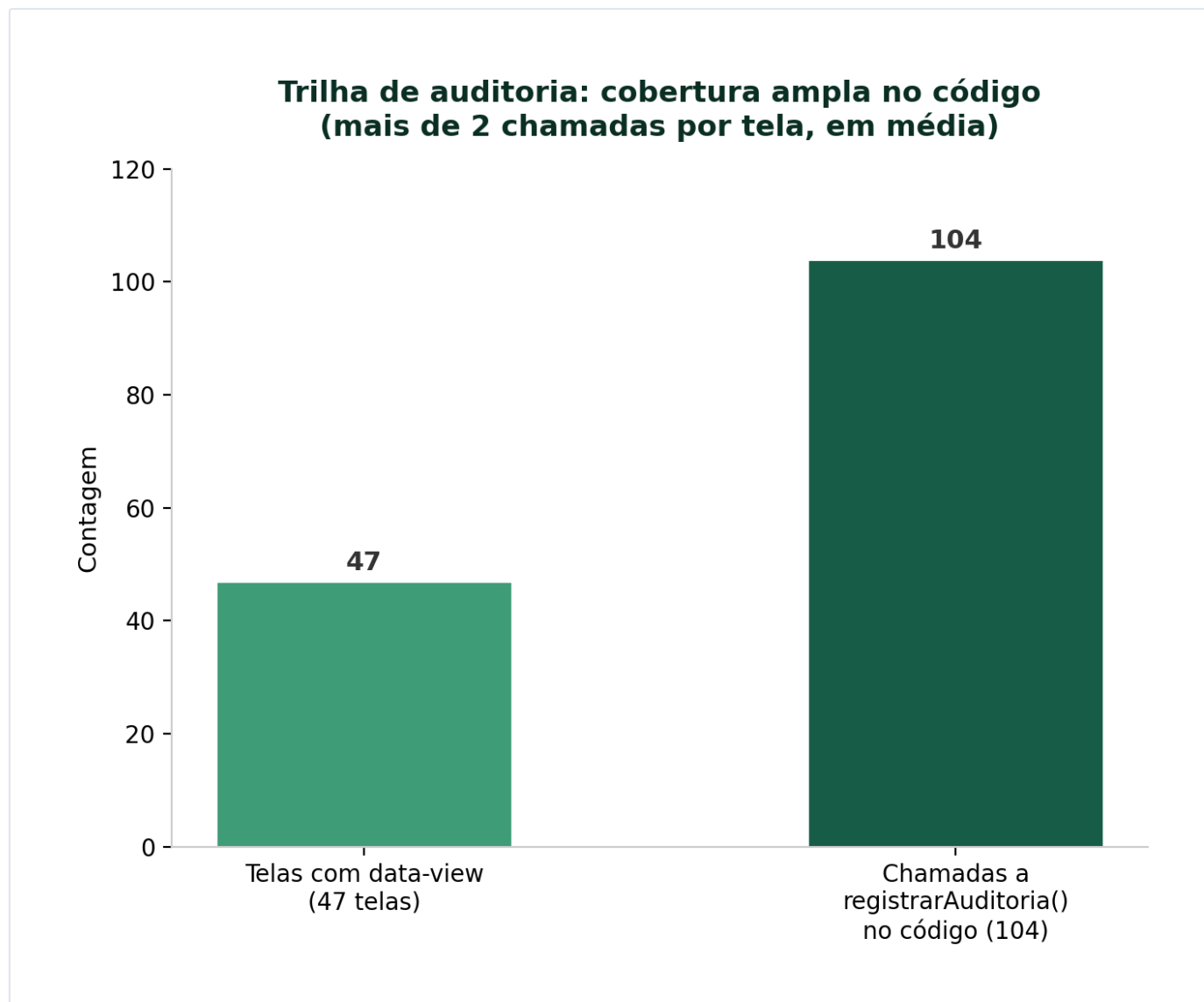
OS QUATRO GRÁFICOS GERADOS A PARTIR DOS NÚMEROS LEVANTADOS NESTA AUDITORIA INDEPENDENTE (3/4)



EXPORTAÇÃO NATIVA POR FORMATO, NO SISTEMA DESKTOP

C Anexo C — Gráficos da Auditoria (continuação)

OS QUATRO GRÁFICOS GERADOS A PARTIR DOS NÚMEROS LEVANTADOS NESTA AUDITORIA INDEPENDENTE (4/4)



TRILHA DE AUDITORIA: COBERTURA NO CÓDIGO